Policy Gap & Compliance Status

1. Responsible AI Policy Gap Analysis

System profile used across this portfolio: FinanceGuard AI is a fine-tuned LLM used for financial document review. It processes PII and confidential financial data through an internal API gateway and operates across a hybrid cloud environment. Current-state evidence indicates incomplete data lineage, monitoring, impact assessment, adversarial testing, transparency, and retention enforcement. These assumptions drive the control ratings and the Conditional Go recommendation.

Gap ID	Responsible AI Principle/Standard Requirement	Identified Deficiency (FinanceGuard AI Context)	Severity Rating (High/Med/Low)	Remediation Action Plan
Gap 1	Privacy and security	PII and confidential financial data lack complete lineage, minimization, retention, and deletion evidence across hybrid-cloud data flows.	**High**	Data Steward and Cyber Security must inventory data flows, document lawful purpose and lineage, enforce minimization and encryption, and test automated retention/deletion before scaling.
Gap 2	Reliability and safety	The API gateway does not produce a complete, reviewed record of prompts, outputs, anomalies, or data-exfiltration indicators across all environments.	**High**	Cyber Security must enable centralized logging and continuous detection, define alert thresholds, conduct weekly review, and retain incident and remediation evidence.
Gap 3	Transparency and accountability	No approved impact assessment or model card fully explains intended use, limitations, bias risks, human-review boundaries, and accountable remediation owners.	**Medium**	AI Program Lead and Model Owner must complete an impact assessment, model card, user guidance, human-review criteria, and quarterly governance attestation.

2. ISO/IEC 42001 Compliance Control Matrix Excerpt

Control ID	ISO/IEC 42001 Standard Control Title	Control Intent & Objective	Implementation Status (Implemented/Partial/Gap)	Evidence/Validation Method
A.5.2	Data for AI Systems	Ensure fine-tuning and validation data is high quality, representative, and collected within appropriate privacy boundaries.	**Gap**	No complete data lineage or sanitization logs. Required: approved source inventory, lineage map, minimization record, consent/legal-basis review, and deletion-test results.
A.6.2	Logging and Monitoring	Record inputs, outputs, and runtime behaviors through the internal API gateway to detect anomalies or data exfiltration.	**Partial**	Gateway logging exists as a design element, but coverage and review evidence are incomplete. Required: configuration export, log samples, alert rules, review tickets, and retention settings.
A.7.2	AI System Impact Assessment	Assess consequences of automated document review on stakeholders and regulatory filings.	**Gap**	No approved impact and bias/fairness assessment. Required: signed assessment, test methodology, results, risk acceptance, and remediation plan.

Control ID	ISO/IEC 42001 Standard Control Title	Control Intent & Objective	Implementation Status (Implemented/Partial/Gap)	Evidence/Validation Method
A.8.3	Security of AI Systems	Protect the LLM infrastructure from adversarial attacks, prompt injection, and unauthorized model-weight modification.	**Partial**	Hybrid-cloud protections are not fully validated. Required: vulnerability and prompt-injection test reports, access-control review, change logs, and remediation closure.
A.9.2	AI System Transparency	Document model capabilities, limitations, intended use, and human-review expectations for internal analysts.	**Partial**	User-facing documentation is incomplete. Required: approved model card, limitations, prohibited uses, human-validation guidance, and training completion records.